

Clase 257 — Pretexting y vishing

Parte: **12 — OSINT e ingeniería social** · Fuente: *Social Engineering: The Science of Human Hacking* (C. Hadnagy) 🕒 Duración estimada: **100 min** · Nivel: **Avanzado**

🎯 Objetivo

Aprender a construir pretextos verosímiles y a ejecutar vishing (voice phishing) dentro de un engagement autorizado, así como a documentar y medir estos vectores. El alumno terminará capaz de diseñar un guion, preparar identidades de apoyo y realizar una llamada de prueba controlada, siempre con permiso escrito y con foco en la mejora de la defensa.

⚖️ Nota ética y legal

El pretexting y el vishing implican **engañar a personas reales**, por lo que requieren **autorización explícita y por escrito** de la organización objetivo, respeto a la legislación (grabación de llamadas, suplantación, protección de datos) y un plan de cuidado de las personas. Nunca llames a alguien sin que su organización lo haya autorizado. Practica los guiones **entre compañeros que consientan**, no contra terceros.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Construir** un pretexto coherente a partir del OSINT previo.
- 2. **Redactar** un guion de vishing con objetivos y ramas de conversación.
- 3. **Aplicar** técnicas de elicitación y manejo de objeciones de forma ética.
- 4. **Preparar** el soporte de identidad (número, contexto, spoofing legalmente permitido).
- 5. **Documentar** la llamada y extraer métricas defensivas.

📖 Temas

#	Tema	Por qué importa
1	Anatomía de un pretexto	Credibilidad = éxito o fracaso
2	Del OSINT al guion	Los datos dan verosimilitud
3	Elicitación conversacional	Obtener sin preguntar directo
4	Manejo de objeciones	Superar la desconfianza sin coerción
5	Vishing: preparación técnica	Números, spoofing, entorno
6	Grabación y legalidad	Consentimiento y jurisdicción
7	Debrief y métricas	Convertir el ejercicio en aprendizaje

Definiciones y características

- **Pretexting:** crear un escenario/identidad falsa para justificar una petición. Característica: se sostiene en detalles obtenidos por OSINT.
- **Vishing:** phishing por voz/teléfono. Característica: la voz añade presión y autoridad en tiempo real.
- **Elicitación:** extraer información con conversación natural. Característica: la persona no percibe que está siendo interrogada.
- **Caller ID spoofing:** falsificar el número que aparece al receptor. Característica: legal solo en contextos autorizados y según jurisdicción.
- **Objeción:** resistencia del objetivo ("no puedo darte eso"). Característica: se maneja con empatía, no con presión abusiva.
- **Debrief:** reunión posterior para explicar el ejercicio. Característica: protege a las personas y consolida el aprendizaje.

Herramientas y preparación

- **Guion y árbol de decisión:** documento con objetivo, apertura, ramas y salida.
- **Telefonía de prueba:** VoIP (p. ej. un softphone) con número dedicado del engagement; spoofing solo si el contrato y la ley lo permiten.
- **Grabación:** con consentimiento y cumplimiento legal; almacenamiento seguro de la evidencia.
- **Entorno de ensayo:** compañeros que consientan para practicar el guion sin objetivos reales.
- **Recordatorio:** sin autorización escrita de la organización objetivo, no hay llamada real.

Laboratorio guiado (autorizado / entre compañeros)

1. Toma el dossier OSINT de un objetivo **de laboratorio** (empresa ficticia) y extrae datos útiles.
2. Define el **objetivo de la llamada** (ej.: verificar si el helpdesk resetea contraseñas sin validar identidad).
3. Redacta el pretexto: identidad, motivo creíble, urgencia moderada, coherencia con el OSINT.
4. Escribe el guion con apertura, 3 ramas de conversación y una salida limpia.
5. Ensaya con un compañero que hace de "objetivo"; graba solo con su consentimiento.
6. Practica la elicitación: obtén un dato objetivo sin preguntarlo de forma directa.
7. Maneja una objeción ("no doy esa información") con empatía y sin coacción.
8. Haz el **debrief**: explica el ejercicio, agradece y anota qué controles fallaron.
9. Registra métricas: ¿se validó la identidad?, ¿se reportó la llamada sospechosa?

Ejercicios

1. Escribe dos pretextos para el mismo objetivo y compara su verosimilitud.
2. Convierte 5 datos OSINT en frases que refuercen la credibilidad del guion.
3. Redacta 3 técnicas de elicitación y ensáyalas con un compañero.
4. Diseña respuestas éticas a 4 objeciones comunes.
5. Investiga la legalidad de grabar llamadas y del spoofing en tu país.
6. Propón un control de helpdesk que frustre tu propio pretexto.

Reto verificable

Diseña y ensaya (entre compañeros que consientan) una **llamada de vishing de laboratorio** con guion, pretexto sustentado en OSINT, manejo de una objeción y un debrief documentado. **Criterio de aceptación:** el ejercicio no involucra a terceros no consintientes, respeta la ley de grabación y produce al menos dos recomendaciones defensivas concretas para el helpdesk.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
El objetivo desconfía de inmediato	Pretexto incoherente con el OSINT. Refuerza detalles y naturalidad.
Presión excesiva sobre la persona	Cruzaste a la coacción. Usa empatía; el objetivo es probar controles, no doblegar personas.
Problema legal por grabar	No hubo consentimiento/aviso. Verifica la ley antes de grabar.
Sin datos útiles tras la llamada	Faltó objetivo claro. Define qué información/acción concreta buscas.
Persona molesta tras el ejercicio	No hubo debrief. Explica siempre y cuida a las personas.

Preguntas frecuentes

 **¿Puedo falsificar el número (spoofing)?** Solo si el contrato lo autoriza y la ley de tu jurisdicción lo permite. En muchos lugares el spoofing fuera de pruebas autorizadas es delito.

 **¿Qué hago si logro comprometer algo real?** Detente, documenta y escala según las Rules of Engagement. No profundices más allá del alcance.

 **¿El vishing sigue funcionando?** Sí, es de los vectores más efectivos: la voz añade autoridad y urgencia que el correo no transmite.

Referencias

- Hadnagy, C. *Social Engineering: The Science of Human Hacking*. Wiley.
- Social-Engineer — Vishing resources. <https://www.social-engineer.org/>
- MITRE ATT&CK — Phishing: Voice (T1566.004). <https://attack.mitre.org/techniques/T1566/004/>
- Cialdini, R. *Influence: The Psychology of Persuasion*.

Siguiente clase

Clase 258 - Campanas de phishing con GoPhish